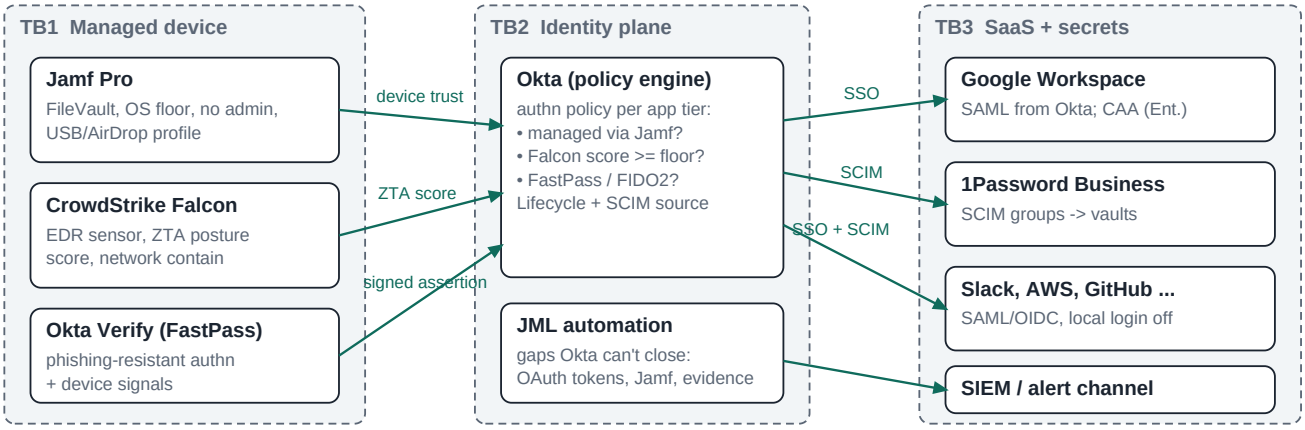
Mal — Endpoint-to-Identity Security Architecture

Companion to Part 1 (`mal-jml`). Vishnudev Ammuppilly · October 2026 · Assumptions: ~50 staff scaling to 200, macOS-majority fleet, Google Workspace as productivity suite, regulated fintech handling customer financial data.

1. Stack design rationale

Principle: Okta is the only door. Every SaaS app authenticates through Okta (SAML/OIDC) with local/password login disabled, so one policy engine decides access and one lifecycle event revokes it. Device posture is an *input* to that decision, never a parallel gate that users can route around.



EDR choice: CrowdStrike Falcon. Defender's main advantage is bundling with Microsoft 365 and Entra conditional access; Mal is on Google Workspace and Okta, so that advantage mostly disappears, and Falcon's macOS sensor and native Okta integration (Zero Trust Assessment score consumed in Okta device assurance) are stronger fits. Check Point Harmony is credible but has the weakest identity integration of the three. Cost is the honest counter-argument; at 50 seats it is material.

Trust boundaries

Boundary	What crosses it	Control
TB1 → TB2 device to IdP	User authentication + device signals	Okta Verify FastPass (phishing-resistant, bound to device keychain); Jamf device trust proves "managed"; Falcon ZTA score proves "healthy". Unsigned or stale signals = unmanaged.
TB2 → TB3 IdP to apps	SAML/OIDC assertions; SCIM provisioning	Per-app authentication policy tiers. Okta pushes users/groups to apps via SCIM so app access follows Okta group membership, not manual grants.
Inside TB3: 1Password	Vault keys	Separate cryptographic trust domain (Secret Key + account password). **Trade-off:** "Unlock with SSO" improves usability but collapses 1Password's independence into Okta. Recommendation: SSO unlock for staff, Secret Key + password retained for owners/admins.
Admin plane	Okta, GWS, Jamf, Falcon admin consoles	Separate admin identities, FIDO2 only, managed device required, no standing super-admin; break-glass accounts sealed in 1Password with alerting on use.

How posture feeds conditional access

- **Tier 1** (GWS, Slack): managed device (Jamf) + FastPass. Unmanaged devices get browser-only access with download/print restricted via GWS Context-Aware Access — which requires an Enterprise edition, so check licensing before promising it.
- **Tier 2** (1Password, AWS console, GitHub org, production data, payment back-office): managed + Falcon ZTA score above an agreed floor + FastPass/FIDO2, shorter session lifetime, re-auth on every new session. Unmanaged = deny.
- **Known gap:** posture is evaluated at sign-in, not continuously. A device that turns unhealthy mid-session keeps its session until it expires. Closing that needs continuous signal sharing (Falcon → Okta via Shared Signals/CAEP, e.g. Okta Identity Threat Protection, a paid add-on). Day one mitigation: short Tier 2 session lifetimes plus a SOAR playbook that calls the same Okta `clear_sessions` used in Part 1 when Falcon raises a high-severity detection.

2. DLP and email security posture

At 50 people the real DLP risk is not a sophisticated insider; it is customer data shared to a personal Gmail, a public Drive link, an over-scoped OAuth app, or a secret pasted into Slack. Day one targets those paths with controls that have near-zero false positives. Content inspection, which is expensive to tune, comes later.

Channel	Day one (50 people)	Defer (to ~100–200)
Email (GWS)	Block automatic forwarding to external domains. Outbound content rule for card numbers (PAN with Luhn check), IBANs and Emirates ID patterns to external recipients: warn then quarantine. TLS enforced to known partners.	Gmail DLP with custom detectors and exact-data matching for customer records (Enterprise tier); attachment sandboxing beyond the Gmail default.
Drive / SaaS	External sharing limited to allowlisted partner domains; no "anyone with link" in shared drives that hold customer data. Third-party OAuth apps restricted to an allowlist (API controls). This is what makes Part 1's token revocation a short list rather than a surprise.	Drive DLP labels and auto-classification; SSPM/CASB for shadow SaaS once app count exceeds what one person can review quarterly; Slack DLP (Enterprise Grid only).
Endpoint	Jamf: FileVault, no local admin, removable storage read-only, AirDrop limited to managed contacts. Falcon USB device control in monitor mode. GitHub secret scanning with push protection.	Full endpoint content DLP (clipboard, print, upload inspection): highest false-positive rate and cost. Justified once there is a data-classification scheme people actually apply.
Policy	Three-tier data classification (Public / Internal / Confidential-Customer) written in one page; DLP rules map to the top tier only.	Labelling enforced in tooling.

SPF / DKIM / DMARC

A fintech domain is a high-value spoofing target (fake payment instructions, fake support). The end state is **DMARC p=reject** on every domain, reached by a staged ramp, not on day one, because enforcing before every legitimate sender is aligned silently drops real mail such as transactional email, the HR system and invoices.

- **Day one:** inventory every sender. DKIM 2048-bit for GWS and every third-party sender, each signing as the Mal domain. SPF lists only real senders and stays under the 10-DNS-lookup limit. DMARC `p=none; rua=` to a report processor. Every parked or non-sending domain gets `v=spf1 -all`, DMARC p=reject and a null MX immediately, since there is nothing to break.
- **Weeks 2–6:** fix alignment from aggregate reports, then `p=quarantine` with pct ramping to 100, then `p=reject; sp=reject`. Move marketing/transactional mail to subdomains so a vendor compromise is isolated from the corporate domain.
- **SPF ~all vs -all:** with DMARC at reject, `~all` on sending domains is fine and avoids some receivers hard-failing forwarded mail before DMARC is evaluated; DMARC is the enforcement point. `-all` on non-sending domains.
- **Also day one:** MTA-STS (enforce) + TLS-RPT. **Deferred:** BIMI (needs a VMC/CMC; a brand feature, not a security control) and lookalike-domain monitoring (worth buying at around 100 staff).

3. What I cut in Part 1 and why

Built against real APIs: Okta (Users, Groups, Lifecycle, Sessions), Google Workspace Admin SDK (users, tokens, signOut), 1Password SCIM Bridge, Slack webhook with SMTP fallback. Each runs live when its credentials are present and otherwise against fixture-backed mocks through the *same* HTTP client, so mock runs still exercise payloads, retries and error paths. 32 tests run at HTTP level. Live-tenant verification is tracked in the README checklist. **Mocked:** Jamf (no free tenant). Its XML payload is modelled on the Classic API `computerinvitations` resource and has not been validated against a real Jamf instance.

Deviation from the brief: the brief suggests the 1Password Connect or Events API. Neither can change vault access: Connect manages items, and Events is read-only. Vault access in 1Password Business is granted to groups, and SCIM controls group membership and suspension, so I used SCIM. Events is the right tool for *verifying* a leaver afterwards, and I did not build that.

Shortcut in the build	Production at Mal
Custom script provisions GWS and 1Password directly.	**Biggest change:** Okta lifecycle management with SCIM push to GWS and 1Password, driven by HRIS as source of truth. The script shrinks to what Okta cannot do: GWS OAuth token revocation and signOut, the Jamf invite, cross-system alerting and evidence.
Okta SSWS API token (admin-scoped, long-lived).	OAuth 2.0 service app, `private_key_jwt`, scopes limited to `okta.users.manage` / `okta.groups.manage`.
GWS service-account JSON key on disk.	Workload identity federation with no long-lived key; delegation limited to the two scopes used.
Secrets from environment variables.	Pulled at runtime from 1Password Secrets Automation or a cloud secret manager; never in CI variables.
CLI trigger, in-process retries only.	HRIS webhook into a queue with idempotency keys and dead-lettering, so a failed step is retried and can't be lost when the process dies.

Shortcut in the build	Production at Mal
Audit log is a local JSONL file.	Shipped to the SIEM with immutable retention; the alert links to the run ID.
No read-back verification.	After the leaver flow: re-read Okta status, list GWS tokens (expect zero), check 1Password Events for later sign-in attempts; report fails if any check fails.
GWS account not suspended; no Jamf lock/wipe; no mover flow.	Suspend after manager handover of Drive/Calendar data; device lock on the termination date with remote wipe after the return window; mover = group diff with removals applied before additions.
Protected 1Password groups (Owners) skipped.	Correct behaviour, but needs a named human step in the runbook with an SLA, not just a log line.

4. Compliance mapping (ISO/IEC 27001:2022 Annex A)

A.5.18 Access rights — provisioning, review, modification and removal of access in line with policy.

How the build addresses it: the leaver flow removes access across IdP, email, OAuth grants and vaults in one run, with step-level timestamps and an explicit failure list. Each run writes a redacted record (run ID, subject, every action, result) to the audit log. That record is the removal evidence an auditor samples against the leaver list. Joiner access is assigned by group, not per user, which keeps grants consistent with a role.

Gaps for audit: (1) there is no link to an authorising record. Group selection comes from CLI arguments rather than an approved HR role mapping, so the auditor can't trace access back to an approval. (2) There is no termination timestamp from HR, so the removal SLA (for example "same business day") can't be proven. (3) Periodic access reviews, which are part of this control, aren't covered at all. (4) Log integrity: a local file the operator can edit is weak evidence until it is shipped to immutable storage.

A.5.16 Identity management — the full lifecycle of identities is managed.

How the build addresses it: one identity (the work email) is created consistently across Okta, GWS and 1Password. Joiner calls are idempotent, so reruns don't create duplicates. Leaver suspends rather than deletes by default, which keeps the identity and its history attributable while access is removed. Deactivation is an explicit flag.

Gaps for audit: (1) there is no reconciliation. Accounts created outside the workflow (local SaaS logins, shared or service accounts) are invisible to it, and the auditor will ask how orphaned accounts are detected. A scheduled job diffing HRIS against Okta and each app closes this. (2) Service and non-human identities have no owner or review cycle. (3) There is no defined retention or deletion point after suspension.

Note: if Mal operates under a CBUAE licence, the same evidence supports the regulator's access-control expectations. I would check the specific technology-risk requirements against the licence category before claiming coverage.